Threat evolution in Q3 2018

GROUP-IB
GLOBAL CYBER SECURITY COMPANY

Table of contents

Introduction 3
Executive summary 4
Forecasts for Q4 2018 8
APTs targeting the Financial Sector 9
Financial Threats 12
- Malicious Android Apps 13
- Banking threats for PC 14
- Exploits 20
- ATM and POS Terminal Attacks 21

State-sponsored APTs 22
Threats to blockchain projects and cryptocurrencies 31
Data leakage 34

Introduction

Every quarter, Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on Europe, Russia, the USA, Canada, and Australia. This document also provides a comprehensive description of threats to governments, including state sponsored targeted attacks and significant data leaks.

To collect data and inform our clients, we analyze various botnets and malware while conducting incident response, monitoring underground forums and accumulating information on new trends, threats and data leaks. Every day, we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages and announcements on the dark web, as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Executive summary

Targeted attacks on the financial sector

In Q3 2018, the following APT campaigns against financial institutions were identified:

- The Cobalt group continued their attacks. Group-IB specialists identified seven campaigns that used both the JS Backdoor of the criminal group and their malware CobInt. Emails purported to be from the following organizations: European Banking Federation, European Bank, Interkassa payment system, SEPA Europe, Alfa Bank, Raiffeisen bank.
- The MoneyTaker group attacked Russia's PIR Bank and withdrew 58 million rubles.
- The Lazarus group continued their activities against cryptocurrency exchanges and their users. In addition, they are reportedly linked to attacks on banks in Vietnam and India in July and August 2018, respectively. Lazarus may have also been behind the attacks using the new ransomware Ryuk and extortion of cash in the cryptocurrency industry.
- In early September, Group-IB released a detailed report on the Silence hacker group "Silence: Moving into the darkside". The documents outline tactics and tools employed by Silence. While the gang previously targeted Russian banks, Group-IB experts also discovered evidence of the group's activity in more than 25 countries worldwide. The confirmed damage from Silence's activity is estimated at 800,000 USD. The group is currently active.

Financial threats

- Since August, we have observed a significant increase in the number of thefts from Russian banks using the Asacub banking Trojan. In these attacks new versions of the malware—5 and 6—were used. Group-IB specialists note that the new versions were written in C ++ (the previous ones were in Java) and have a slightly different functionality. Its main goal remains the same—theft of money from bank clients. However, the sharp increase in the number of attacks is due to the fact that the attackers began to use more aggressive and mass SMSs for infections, rather than due to the emergence of the new versions.
- Russian banks were also attacked using Agent.BID and FlexNet.
- Activity of the Agent.sx and Limebot Android banking Trojans decreased.
- RTM and Buhtrap were used to attack customers of CIS banks, including the Buhtrap version with the autoloading module into 1C. Group-IB specialists identified a network of accounting websites that infected visitors with the Buhtrap and RTM banking Trojans. We also note a large number of mailouts containing RTM and that this malware has resurfaced after a long hiatus.
- It was found that the Osiris bank Trojan that came into season last quarter is the modified version of Kronos malware.
- As expected, the BackSwap bank Trojan uncovered last quarter expanded its geographical scope and started attacking Spanish banks. Note that BackSwap uses a unique technique: it injects malicious code not into browser processes but a web page through the browser developer console or into the address line, which makes it hard to detect.
- Some malicious mailouts to banks occurred that contained malicious RAT programs: FlawedAmmyy and Adwind/jRAT.
- The Electronic Document Exploitation Kit exploit pack sold on underground forums currently includes the following exploits: CVE-2018-4985, CVE-2018-4990, CVE-2018-4901, CVE-2018-4872, CVE-2018-4993, CVE-2018-12815. These exploit vulnerabilities to bypass a sandbox of Adobe Reader. We should also note that attackers have been actively using this exploit pack recently.
- The Fallout exploit pack is now available too. It includes exploits for CVE-2018-4878 in Adobe Flash Player and CVE-2018-8174 in VBScript.

- The ThreadKit exploit kit was supplemented by an exploit for the CVE-2018-5002 vulnerability.
- Gozi banker (aka ISFB/Ursnif/Dreambot) attacked Australian and Japanese banks.
- Underground resources started to sell a new universal stealer called KPOT Stealer.
- A new service for making web injects was launched (Happy_milkman).
- The Gootkit bank Trojan, which earlier attacked European banks, is much less active.
- The Red Alert Android Trojan is still actively updated and sold. It is targeted at many banks in Europe, Australia, India and the United Arab Emirates.
- The author of AndyBot Android banker, bestoffer, reported that quite a number of users are renting the Trojan and new applications are currently suspended. We would like to note that this Trojan targets banks in the USA, Australia, and Europe.
- The Ramnit Trojan has been more active recently.
- Black Box attacks on ATMs were detected in Italy. It was also found that malicious actors are offering an ATM Jackpotting service via underground platforms.
- The Tinba Trojan was used to steal bank card data from Canadian and Australian banks.
- TinyNuke is still attacking French banks and now also Polish banks.
- ICEDID is still attacking banks in the USA, Canada, and the UK. Attackers use Emotet to deliver it.
- Trickbot attacked financial organizations in the USA, Canada, the UK, Spain, and Germany.
- Qbot injects were targeted at financial organizations in the Netherlands, the USA, Canada, and Spain.
- TinyNuke continues to attack French banks. The target list now also includes Polish banks.
- In early July, an archive became publicly available that was called Pegasus Framework For Attacks. Later, Group-IB experts found out that the published source code is actually Buhtrap malware.
- On September 6, British Airways reported the compromise of user data on their website and mobile app. All users who booked their flights via the official website or mobile app from August 25 to September 5, 2018, were at risk. Attackers reportedly stole data of 380,000 users. Group-IB experts believe that credit card sniffers could be used in such attacks.

Threats to blockchain projects and cryptocurrencies

In Q3 2018, the following APT campaigns targeting cryptocurrencies were detected:

- Since July 2018, the Lazarus hacker group has been attacking cryptocurrency exchanges and their users using a Trojanized trading application called Celas Trade Pro.
- Hackers stole $60 million of digital coins from Zaif, a Japanese exchange owned by Osaka-based Tech Bureau Corp.
- In July, an unknown attacker managed to gain access to the account of the KICK smart contracts and the tokens of the KICKICO platform. The security breach resulted in hackers stealing $7.7 million.
- In July 2018, a cryptocurrency wallet and decentralized exchange Bancor was hit with a hack. A wallet the Bancor team used to upgrade some smart contracts was compromised, and a total of roughly $23.5 million-worth of Ether, Pundi X (NPXS) tokens, and Bancor Network tokens (BNT) were stolen.
- In September, hackers were able to steal nearly $58,000 worth of cryptocurrency from the Newdex exchange by exploiting a vulnerability in the exchange. The criminals flooded the Newdex exchange with 1 billion fake EOS tokens they created themselves to buy ADD, BLACK and IQ tokens from the centralized platform.

Data leaks

- Switzerland-based data management company Veeam reportedly left exposed a database containing more than 200 gigabytes of customer information. The more than 440 million records mostly consisted of names, email addresses and IP addresses.
- In August 2018, a data breach hunter discovered a single file on an unsecured server that contained 14.8 million records linked to registered voters in the state of Texas.
- Fiserv, Inc., a major provider of technology services to financial institutions, just fixed a glaring weakness in its web platform that exposed the personal and financial details of countless customers across hundreds of bank websites.
- In late August, the telecom giant, T-Mobile, suffered a security breach on its US servers, exposing personal information of roughly 2 million customers.
- A 16-year-old student living in Australia is facing criminal charges after he broke into Apple's network multiple times and downloaded 90GB of private data for an entire year. The name of the arrested boy and some details of the attacks have not been released for legal reasons.
- In late August, Chinese media reported that a database containing personal data of over 130 million Chinese hotel guests was put up for sale on a Chinese underground forum.

Threats to the Government sector

Governments are always going to be under the threat of cyber espionage and in some cases suffer attacks to critical infrastructure. Group-IB specialists perform an independent analysis of such threats and are well-informed about the results of global expert studies. In Q3 2018, the following active APT campaigns targeting governments worldwide were detected:

- The APT28 group conducted a campaign targeting the Italian Navy and its contractors. This new campaign was dubbed Operation Roman Holiday.
- In September 2018, the recently detected hacker group, PowerPool, started using the 0-day vulnerability CVE-2018-8440 (a vulnerability that allows privilege escalation to SYSTEM when processing ALPC calls).
- A cyber espionage campaign called Operation NuclearCrisis by Sapphire Mushroom hackers was detected. The campaign was targeted at Chinese R&D institutions, government and defense agencies.
- Before the ARMY 2018 International Military-Technical Forum, a BISKVIT attack targeted at participants was detected.
- The recently discovered Indian hacker group, Sidewinder, is spying on Pakistani military interests.
- Chinese hackers from TEMP.Periscope conducted a campaign targeted at Cambodian political parties just before the general elections on July 29, 2018.
- The pro-Iranian hacker group, OilRig, continued their attacks on the Middle East but this time they added a new tool: QUADAGENT backdoor.
- Cybercriminals from Gaza Cybergang relaunched their attack on the Middle East and Palestinian administration in particular.
- Hackers from the recently uncovered WindShift group conducted a campaign against government agencies and critical infrastructure companies from the Middle East. To prepare the attack, hackers conversed with victims in social media from 6 months to a year.
- The Pakistani Gorgon Group attacked government agencies in the UK, Spain, Russia and the USA using NanoCoreRAT, QuasarRAT or NJRAT.
- The Turla group used their Outlook backdoor to attack European government institutions. The main feature of the new backdoor is that it receives commands in PDF files sent via email.
- Chinese hackers from APT10 attacked Japanese targets again. They used the updated UPPERCUT backdoor.

- APT-C-35 modified their tools and are currently using a mobile RAT against government institutions in the Kashmir region.
- The DarkHotel group added to their arsenal the two 0-day vulnerabilities CVE-2018-8174 and CVE-2018-8373 that are associated with the VBScript Engine.
- The Red Signature operation lasted for two weeks. The cybercriminals used the compromised support server of a South Korean software vendor.
- Bahamut hacker group started to conduct targeted attacks on iPhones in India and Qatar. Allegedly, their objectives are espionage and data theft.
- A new malicious campaign of the Chinese LuckyMouse group targeted government agencies in the Middle East.
- A Vietnam-based cyberespionage group OceanLotus added a new backdoor to its arsenal, but continued to use an old and publicly known infection technique. The trick is to take advantage of the library loading process of a legitimate and signed executable by writing a malicious library inside the same folder. This way, it will make malicious behaviors look legitimate because these actions are made by the trusted executable process.

Forecasts for Q4 2018

- Asacub will remain the most active banking Trojan for Android in the CIS.
- The BackSwap banking Trojan will likely expand its target list to include other banks in Europe and North America.
- RTM and Buhtrap Trojans will be used in the CIS to attack bank customers, primarily legal entities.
- Hackers will attack banks by sending emails containing RAT tools, primarily FlawedAmmyy and Adwind.
- Gozi will continue to attack banks in Australia and Japan without expanding its geography.
- We assume that the new stelaer dubbed KPOT Stealer will gain popularity and will compete with the widely used AzoRult stealer.
- Red Alert and AndyBot Trojans will be used to attack Android devices abroad, in Russia—Asacub, Flexnet and Agent.BID.
- IcedID and Trickbot will remain the most dangerous banking Trojans for Windows outside Russia.
- Attacks on ATMs will continue, as we see that hackers are interested in this target and continue to develop new schemes.
- The Cobalt group will continue to attack banks in the CIS and Europe. Criminals will use fresh exploits primarily for MS Office products, as well as their malware CobInt.
- The Silence group will likely continue to conduct attacks on card processing systems and ATMs. The group targets banks in the CIS and Europe. Also, the threat actors will improve their tools and techniques.
- The North Korean group Lazarus will attack both banks and cryptocurrency services using new malware. Based on their previous attacks, we can conclude that the amount of theft can be significant.
- We believe that the MoneyTaker group will conduct new attacks. ARM CBR and card processing systems are at risk. To prevent attacks, it is critical to maintain a high level of security both in the external perimeter of the organization and in the internal network.

APTs targeting the Financial Sector

GROUP IB

GLOBAL CYBER SECURITY COMPANY

APT name	Regions attacked	Related notifications	Operation start
Cobalt	Global	CP-1438-49 – CP-1438-55	2016

In Q3 2018, the Cobalt group conducted the following attacks:

- On June 29, the Cobalt group sent malicious emails acting as the European Banking Federation. The letters contained a PDF document with a link that downloaded the JavaScript backdoor.
- On July 4, the Cobalt group launched a malicious campaign acting as a legitimate bank in Europe. The emails contained a link to download CobInt malware.
- On July 10, Cobalt sent malicious emails to Bulgarian banks. The letters contained a link to download CobInt malware.
- On August 2, the group sent malicious emails posing as Interkassa payment system. The letters contained links to an executable file, which contained CobInt malware.
- On August 14, the Cobalt group sent malicious emails acting as SEPA Europe. The letters contained a link to download CobInt malware.
- On August 16, the group launched a malicious campaign purporting to be from Russia's Alfa Bank. The letters contained a link to download an exploit for CVE-2017-11882 and then download CobInt.
- On August 4, the group sent emails purporting to be from Raiffeisen bank. The letters contained a link to download an exploit for CVE-2018-8174 and then download CobInt.

APT name	Regions attacked	Related notifications	Operation start
MoneyTaker	Russia	CP-1714	May 2018

In early July 2018, the Money taker group stole funds from Russia's PIR Bank. The attack started in late May 2018. The entry point was a compromised router used by one of the bank's regional branches. The router had tunnels that allowed the attackers to gain direct access to the bank's local network. When the criminals hacked the bank's main network, they managed to gain access to AWS CBR (Automated Work Station Client of the Russian Central Bank), generate payment orders and send money in several tranches to mule accounts prepared in advance. Most of the stolen money—about $900,000—was transferred to cards of the 17 largest banks on the same day and immediately cashed out by money mules involved in the final stage of money withdrawal from ATMs. Simultaneously, the attackers used a technique characteristic of MoneyTaker to cover their tracks in the system—they cleared the OS logs on many computers to hinder the response to the incident and its subsequent investigation.

MoneyTaker is a financially-motivated hacker group, which has been tracked since May 2016. The group primarily targets card processing systems in US banks and Russian systems of interbank transfers. The group's arsenal also includes self-developed malware designed to attack ATMs, which was first discovered by Group-IB in May 2018.

APT name	Regions attacked	Operation start
Lazarus	Global	July 2018

In mid-August, experts discovered targeted attacks conducted with a new Ryuk cipher. The campaign was conducted in several countries and earned criminals $640,000 in bitcoins. Experts believe that Lazarus group, which is allegedly associated with North Korea, was behind the Trojan. The assumption arose from the fact that Ryuk has similarities with Hermes ransomware from the Lazarus arsenal.

Both malware programs use nearly identical encryption functions and scripts. There is a similarity in their behavior: tagging the converted files, bypassing the specific files, etc. Some differences were discovered as well: before you start working, Ryuk stops 40 processes and 180 services on the infected machine.

For each victim, the attackers prepared an individual scenario, including messages demanding money, which depended on the paying capacity of the victim. It was confirmed that two American companies and one organization in Germany suffered from the cybercriminals' actions.

Earlier in July, the Vietnamese CERT (VNCERT) released a warning message that at the end of June 2018 hackers attacked some banks and major divisions of IT infrastructure in Vietnam. As stated in the announcement, hackers penetrated the target facilities. They sought to take control of users' computers and to penetrate other computer systems containing important information. The notification also contained information about IP addresses of criminals that must be monitored and blocked. In addition, VNCERT listed possible hashes of malicious files. Security experts commented that these files were found in July 2018 at a Vietnamese bank called Saigon Thuong Tin Commercial Joint Stock Bank (Sacombank). The malicious file code has similarities with the malware used in the attack on the Taiwan Far Eastern International Bank in 2017. In that case, the attackers were from Lazarus, a North Korean cybercriminal group. According to our data, Sacombank was presumably infected in 2016 and the actions of cybercriminals may have gone undetected until July 2018.

Another attack, which was supposedly carried out by hackers from Lazarus involved hacking Cosmos Bank from India. In total, the Bank and its clients lost more than $13 million.

Apparently, the attack was divided into two phases. The first phase was carried out on August 11, 2018, from 15:00 to 22:00 local time. At this time, the mules in 28 countries massively withdrew money from local ATMs.

The second phase began on Monday, August 13, 2018. The attackers used SWIFT and transferred almost $2 million to an account in a Hong Kong Bank.

Securonix Threat Research experts suggested that the attack on the Indian Bank was conducted with malware and an infected Central ATM/POS switch. When the first stage of the attack was finished, the malware probably broke the connection between the central systems and core banking system (CBS) to prevent the verification of the transaction. Experts claim that the attackers used 450 cloned debit cards in 28 countries around the world to implement the transactions.

Researchers said that "Attackers might send fake Transaction Replies (TRE) in response to the Transaction Request (TRQ) from the card holders and terminals. As a result, the messages required by ISO 8583 (international standard for systems that exchange electronic transactions initiated by cardholders using payment cards) are never forwarded to the backend/CBS from a compromised ATM/POS, which allows a malicious withdrawal and affects the possibility of fraud detection in the banking system." Lazarus (other names: Dark Seoul Gang, HIDDEN COBRA, Guardians of Peace) is cyber-crime group, operating since 2007. As experts found out, the members of the hacker group are from North Korea.

Financial Threats

GROUP IB

GLOBAL CYBER SECURITY COMPANY

Malicious Android Apps

Threat name	Detection	Regions attacked
Asacub	2014	Russia

Asacub is distributed through phishing SMS messages. In Q3 2018, hackers actively spread new versions of Asacub—5 and 6. The new versions are developed in C ++, instead of Java. That said, some of the functions of the old version were lost, but it will probably be restored soon. Currently, the application can intercept SMS messages, block incoming calls, display phishing windows (web injections), receive a contact list, make USSD requests, send SMS messages to any number, or to the entire list of contacts on the device, and also receive a list of installed applications.

For the full functioning, the Trojan requires the user to give it additional rights, otherwise part of the functionality will not work. After obtaining the necessary rights, the Trojan begins to completely control the device: it becomes quite problematic to delete the application, since it blocks the user's attempts to use the application manager or the installed popular anti-virus solutions.

Threat name	Regions attacked	Detection
Red Alert	Global	May 2017

Currently, the Red Alert Android banking Trojan is quite popular and often purchased on underground resources. At a relatively low price, the client gets effective malware with a large set of fake pages for attacks on banks worldwide, as well as for cryptocurrency wallets. The author nicknamed Sochi is constantly updating the malware—in March 2018, Red Alert v2 was released. The list of attacked banks is expanding as well. With a list of over 200 targets, criminals are not limiting themselves to banking apps, but expanding their non-banking targets to include mail clients, cryptocurrency apps and various payment systems.

Threat name	Regions attacked	Detection
Agent.BID	Russia	August 2015

Agent.BID is an Android banking Trojan with web injection functionality. We have not observed its activity since late 2016. However, in Q2 2018, they resumed attacks in Russia. In Q3 2018, about **300,000 Android-based devices** were infected, and the botnet continues to grow.

The Trojan displays fake web pages posing as legitimate banking apps, which enables attackers to steal online banking credentials and bank card data.

Threat name	Regions attacked	Detection
FlexNet	Russia	2014

The Trojan requests device administrator privileges. The text of the request is masqueraded as the Google Play Agreement, which distracts the user and leads to the confirmation of rights. In Q3 2018, the malware added 18,000 devices to the botnet.

On command from the C&C server, the application can:

- change the address of the C&C server
- send an SMS message to a specified number
- send spam messages with specified text
- forward SMS messages to the C&C server
- reply to SMS messages and delete them to hide them from the user

- run USSD requests
- create a scheduled task—setting up a command template for new bots, taking into account the operator and the country.

Also, Group-IB specialists determined that authors added phishing dialogs disguised as popular applications to the recent version of FlexNet. The legitimate-looking dialogs are used to steal a victim's bank card data. The following fake dialogs were discovered:
AliExpress
Alpha
Avito
Google Play
MyNewAlpha
telecard
VTB24
Sberbank
Uber

Banking threats for PC

Threat name	Regions attacked	Detection
ICEDID	USA, Canada, UK	2017

Security specialists originally discovered this banking Trojan in late 2017. This malware may be employed to steal financial information and conduct targeted attacks. In Q3 2018, it was distributed by Emotet, another well-known banking Trojan, as well as through phishing campaigns with malicious documents containing macros that download and execute ICEDID on the victim's device.

ICEDID has a modular structure and incorporates techniques of the infamous Zeus Trojan, including web injections, the ability to embed code into processes, and data theft. One of its distinctive features is the ability to deploy a proxy server on an infected machine and redirect all Internet traffic using this server.

The identified ICEDID samples are designed to target the following banks in the US, Canada, and the UK:

HSBC Bank
JPMorgan Chase
Citibank
Bank of America
The Synovus Financial Corporation
Toronto-Dominion Bank (TD BANK)
Chase Bank
Charles Schwab Corporation
Fifth Third Bank (53 bank)
Capital One
Wells Fargo
Post Oak Bank (US)
Halifax
TSB Bank
Usbank
Unionbank (US)

Threat name	Detection	Countries attacked
Qbot	2009	Netherlands USA Canada Spain

Discovered in 2009, the QakBot or Qbot banking Trojan has significantly evolved over time. The malware features a modular design, is multithreaded, and includes components designed to steal keystrokes, online

banking credentials, digital certificates, authentication tokens, and cookies, implement a backdoor, and create a SOCKS proxy. It also has the functionality to bypass AV solutions. The program is primarily used to target businesses, stealing money from their bank accounts. QBot is able to spread like a worm by self-replicating through shared drives and removable media.

Its latest version targets the following banks:

ABN AMRO Bank
Citibank
Huntington Bancshares, Inc.
Toronto-Dominion Bank (TD BANK)
Bank of America
First Citizens Bank
Citizens Financial Group
First Tennessee Bank
Banco Bilbao Vizcaya Argentaria (BBVA)
Eastern Bank
Fifth Third Bank (53 bank)
FirstMerit Bank
JPMorgan Chase
KeyBank
Suntrust
Scotiabank
Usbank
Capital One
Frostbank
PNCbank
Mandtbank
Websterbank

Threat name	Regions attacked	Detection
Gozi (ISFB, Ursnif, Dreambot)	Australia, New Zealand, Japan	2007

In Q3 2018, Group-IB discovered Gozi samples attacking banks in Australia.
Examples of attacked banks:

ANZ
Bankwest
Bendigobank
Commonwealth Bank
NAB
StGeorge
BankSA
Bankofmelbourne
Suncorpbank
Westpac
Macquarie
BNZ
Australianmilitarybank
Adelaidebank
Bankvic
Bananacoast Community Credit Union
Regionalaustraliabank
Customsbank
Fmbank
Gcmutualbank
Humebank
Mycreditunion
Policebank

Samples attacking Japanese banks were detected as well:
Shinkin bank
The Bank of Tokyo-Mitsubishi UFJ
Aeon Bank
Credit Saison
Daishi bank
Hokkoku bank
Resona Bank
Tsukuba bank
Awa bank
Yamagata Bank
Japan Post Bank
Tsukuba Bank
Miyazaki Bank
Hiroshima Bank
Rakuten Bank
Idemitsu Credit Co.
Japan Net Bank

Program Title	Regions Attacked	Detection
Trickbot	USA, Canada, UK, Spain, Germany	Autumn, 2016

Trickbot is a banking Trojan that has similar functionality to Dyre (Dyreza) malware. It is distributed through spam emails and using additional malware Emotet.

The samples detected in Q3 2018 are targeting the following banks:

HSBC Bank
Scotiabank
Toronto-Dominion Bank (TD BANK)
Bank of Montreal
Royal Bank of Canada
Caisses Desjardins
JPMorgan Chase
Usbank
Citibank
Bank of America
Barclays
BB&T Bank
Bank of Scotland
Deutsche Bank
Lloyds Bank
Sparda Bank
Ulster Bank
Banco Bilbao Vizcaya Argentaria (BBVA)
Laurentian Bank of Canada
Blockchain.info
First Citizens Bank
Danske Bank
Huntington Bancshares, Inc.
The National Bank of Canada
Capital One
Citizens Financial Group
Chase Bank
Canadian Imperial Bank of Commerce (CIBC)
Charles Schwab Corporation
NETELLER
Comdirect Bank AG
Commerzbank
Wells Fargo
Fifth Third Bank (53 bank)
Halifax
KeyBank
Sparkasse
Regions Financial Corporation
TSB Bank
Unicredit Bulbank (BG)
Suntrust
Tesco Bank
PNCbank

Title	Detection	Attacked Countries
TinyNuke (aka NukeBot)	2017	France, Poland

TinyNuke Trojan has the following features:

- Formgrabber (Internet Explorer version 8 - 11, Firefox, Tor, Chrome 50 - 55 (HTTP/2, SPDY, SSL))
- Web injects, which are JSON-focused (Internet Explorer 10 to 11, Firefox (all versions), Chrome v. 50 to 55 (HTTP/2, SPDY, SSL)). Web injects are working with x86 and x64 browsers.
- They support SOCKS4 back connection.
- A module for hidden virtual network computing (HVNC), which works on all versions of Windows, from XP to 10.
- Bypassing user account control (UAC).
- Bypassing firewalls in Windows and IBM Trusteer.

Examples of attacked banks:
HSBC (FR)
Bsprudnik (PL)
Bosbank24 (PL)

Threat name	Detection	Regions attacked	Related notifications
RTM	2015	Russia	CP-1739

The modular Trojan is written in Delphi. The Trojan is designed to attack RBS and payment systems. The last detected sample of the Trojan searched for the following RBS systems on the infected machine: BSS_PC, Faktura, HandyBank, QiwiCashier, Raiffeisen, RosBank, SberBank_BO, SberBank_Fiz, SberBank_PC, VTB24.

The RTM group has a main control panel and a separate Proxy panel for banks with which they use a specific technique—all requests are forwarded to phishing servers, where traffic is proxied.

In Q3 2018, we observed an increase in the number of email campaigns distributing RTM. The emails were sent to Russian-speaking legal entities. One of these campaigns was launched on 03.09.2018. It is interesting to note that the emails were sent from a large number of spoofed email addresses, the text of the messages was generated automatically and customized for each recipient. The name of the archive was also unique for each case.

Threat name	Detection	Regions attacked
FlawedAmmyy RAT	2016	Global

In August 2018, targeted mailouts were detected that targeted banks. They used FlawedAmmyy, which is RAT malware and a modified version of the Ammyy Admin application for remote administration.
The mailout was carried out with Necurs botnet. The emails sent contained a PDF attachment or .iqy files (opened with Excel). The PDF contains malicious JavaScript code that attempts to run a document in Microsoft Publisher which contains a malicious VBA macro.
In the end, in the case of a PDF or .iqy file, the victim's machine will run the FlawedAmmyy executable file.

Threat name	Detection	Related notifications	Regions attacked
Adwind/jRAT	2012	CP-1745	Global

On August 28, 2018, emails purporting to be from Punjab National Bank were sent to banks. The letters contained a remote access tool Adwind/jRAT. Purportedly, hackers sent emails from the compromised account of a legitimate employee. The emails with malicious attachments were sent to banks and large companies in India, the Philippines, and Australia.

Threat name	Detection	Related notifications	Regions attacked
Osiris	April 2018	CP-1682	Global

It was found that Osiris banking Trojan, which became available in the underground market last quarter, was a modified version of the Kronos banking Trojan. A little later, the seller decided to abandon renting the program and has decided to sell its source code.

Threat name	Detection	Related notifications	Regions attacked
Buhtrap	August 2015	CP-1715 CP-1716	CIS

In July, Group-IB specialists detected a sample of Buhtrap malware with an autoloading module for the 1C system. This Buhtrap sample was able to bypass the protection of 1C:Enterprise's Security of Exchange With a

Bank. We would like to note that the first Buhtrap sample with an autoloading module was discovered in December 2016.

Also in July, on the underground forums, a data archive was posted, which, according to the description, contained source code of the Pegasus framework (targeting ARM CBR). A study conducted by Group-IB experts showed that this archive actually contained the source code used by Buhtrap group.

We would like to note that in the last six months Group-IB experts have discovered many accounting websites, which infected visitors with Buhtrap and RTM banking Trojans, designed to attack legal entities. The CFOs, attorneys, accountants and other professionals fell victim to the attack because they used remote banking services (RBSs), payment systems or crypto wallets. In July, at least one resource of the attackers was still operating.

Threat name	Detection	Regions attacked
BackSwap	March2018	Spain, Poland

BackSwap is a new banking Trojan that uses new methods to bypass antivirus solutions and steal money from bank customers. Initially (the second quarter of 2018), it was seen in spam mailouts to users in Poland.

BackSwap works with elements of the Windows graphical interface and simulates keystrokes to avoid detection and to bypass browser protection. The hackers who developed BackSwap were discovered in January 2018 when the was group still spreading their malware, for example, a program to steal cryptocurrency that substitutes the wallet address in the clipboard.

Unlike other banking Trojans, BackSwap does not embed malicious code into the browser processes because it is easily detected by antiviruses. Instead, it uses Windows events that wait for the messages to know when the victim visits the online banking system. The malware then injects malicious code into a web page using the developer console of the browser or into the address bar.

In August 2018, it was revealed that BackSwap had begun to attack Spanish banks: Bankia, Santander, Caixa, Sabadell, BBVA.

Threat Title	Detection	Related Notifications	Regions Attacked
KPOT Stealer	July 2018	CP-1730	Global

A sale announcement of the KPOT Stealer password stealer was posted on underground forums. The stealer can gather passwords from various browsers, instant messengers, crypto wallets, FTP, and other programs as well as capture screenshots of the victim. There is a loader function that allows additional malware to be downloaded. Android loader, which went on sale recently, received many favourable reviews from users. We should note that logs of the banks showing results of the malware are already on sale on the underground forums.

Threat Title	Detection	Related Notifications	Regions Attacked
A service for making web injects (Happy_milkman).	August 2018	CP-1723	Global

On August 2, 2018, the user of exploit.in underground forum nicknamed Happy_milkman posted an announcement about a new service for making banking web injections.

The service author offers services associated with the following injects:

- Grabbers to steal passwords, credit card details etc.
- Token panels to intercept one-time passwords and SMS messages.
- Autoloading to automatically conduct fraudulent transactions.

Happy_milkman also announced the sale of prepared injects for cryptocurrency services.

Threat name	Detection	Regions attacked
Ramnit	2010	Global

Check Point experts noted a significant increase in the number of attacks with the Ramnit banking Trojan. Over the past few months, Ramnit has doubled its activity, supported by a large-scale campaign, during which devices of the victims became malicious proxy servers.

Ramnit includes the following modules: a spy module that provides web injection functionality, drive scanner, FTP grabber, cookie grabber, anonymous FTP Server, and VNC module.

Analysis showed that Ramnit attacked following financial organizations from in Japan:

Credit Saison
Idemitsu Credit Co.
Mitsubishi UFJ NICOS Co
Aeon Bank
Life Card Co.
Pocket Card Co.
Cedyna Financial Corporation
Epos Card Co.
Rakuten
Sumimoto Mitsui Card Co.

Botnet is active since August 2018, on the moment of research it contained about ten thousand infected devices. Most of them from Japan, also there ate US, Russian, Canadian devices and other countries in small amounts.

Threat Title	Detection	Regions Attacked
Tinba	2012	Canada, Australia

This malware connects to the browser and steals credentials. It also analyzes network traffic. Just like several other sophisticated banker Trojans, it uses Man in the Browser (MitB) techniques and web injects to change the look and behavior of certain web pages. Its purpose is to bypass Two Factor Authentication (2FA) or to trick the infected user into providing additional sensitive data such as credit card data. In the third quarter, we recorded banking cards of the following banks compromised with Tinba:

The Bank of Nova Scotia,
The Toronto-Dominion Bank,
Commonwealth Bank of Australia
JP Morgan Chase Bank.

Threat Title	Detection	Related Notifications	Regions Attacked
Pegasus framework	July 2018	CP-1715	Global

On July 6, 2018, an underground forum user nicknamed Bobby.Axelrod posted a description of attacks on banks and archive materials related to the attacks that contained the source codes of the Pegasus framework (targeting ARM CBR). This was posted right after the attack on PIR Bank and was presented as if it was the materials of MoneyTaker group.

However, Group-IB experts found out that the published source code is actually Buhtrap malware.

Threat Title	Detection	Related Notifications	Regions Attacked
Credit cards sniffers	September 2018	CP-1760	Global

On September 6, British Airways reported the compromise of user data on their website and mobile app. All users who booked their flights via the official website or mobile app from August 25 to September 5, 2018, were at risk. Attackers reportedly stole data of 380,000 users. The technical details of the attack were not disclosed. However, on 11 September, the company RiskIQ published a research report stating that Magecart group was behind the attack. The attackers injected malicious JS script that collected user data from the airline's website. The mobile app also used the same script from the main website.

Group-IB experts have also begun their investigation. The preliminary research helped to reveal that credit card sniffers sold on underground resources could be used for such attacks. This class of malicious software is created to collect payment information during the payment process in online stores or various online services. The most popular targets for such attacks are the stores run by Magento and OpenCart. The installation of the malicious script starts with getting access to the online store via the control panel or downloaded webshell. This gives an attacker the ability to modify the code of pages where the user is entering payment information: card number, expiration date, CVV and so on. After installing a sniffer, the attacker would have access to all payment information that was entered by the user in the store.

We are continuing our study and all the available information can be found in the CP-1760 report.

Exploits

Threat Title	Detection	Related Notifications	Regions Attacked
Electronic Document Exploitation Kit	June 2018	CP-1710-2	Global

On June 28, 2018, an underground forum user nicknamed Ondrik8 posted a sale announcement of the PDF builder that exploits CVE-2018-4990 and CVE-2018-8120. Later, the attacker updated its product. On July 12, 2018, the seller updated the post, and now the product is called Electronic Document Exploitation Kit. It includes the following exploits: CVE-2018-4985, CVE-2018-4990, CVE-2018-4901, CVE-2018-4872, CVE-2018-4993, and CVE-2018-12815. These exploit vulnerabilities to bypass a sandbox of Adobe Reader.

We assume that the exploit kit will be actively used by attacking criminals.

Threat Title	Detection	Related Notifications	Regions Attacked
Fallout exploit kit	September 2018	CP-1744	Global

The exploit.in user, FalloutEK, announced the sale of an exploit kit called Fallout. The kit includes exploits for CVE-2018-4878 in Adobe Flash Player and CVE-2018-8174 in VBScript. It was used in campaigns against users in Japan, Korea, the Middle East, Southern Europe and other countries in the Asia-Pacific region. This kit was used to distribute malware such as Smoke Loader and GandCrab. The rental price is $500 per week and $1500 per month.

Threat Title	Detection	Related Notifications	Regions Attacked
ThreadKit EK	June 2017	CP-1719	Global

On July 20, 2018, on the exploit.in underground forum, a user nicknamed mrbass posted an announcement about updating the exploit bundle for Microsoft Word called ThreadKit. This update included an exploit for the CVE-2018-5002 vulnerability. The exploit bundle currently includes exploits for the following vulnerabilities: CVE-2017-8570, CVE-2017-11882, CVE-2018-0802, CVE-2018-4878, CVE-2018-8174, CVE-2018-5002 and CVE-2018-8373.

ATM and POS Terminal Attacks

- Black Box attacks on ATMs were detected in Italy.
- Group-IB experts identified the underground forum user nicknamed chegevarrra, who provides an ATM jackpotting service. His accomplice is an intruder called Mr.Markas. The attack works on two models of NCR and three models of Wincor. See notice CP-1750 for details.

State-sponsored APTs

GROUP IB

GLOBAL CYBER SECURITY COMPANY

APT Title	Regions Attacked	Operation Start
APT28	Italy	July 2018

In July 2018, Z-Lab CSE Cybsec specialists discovered samples of malware used by APT28 in the new malicious campaign called Roman Holidays. The likely attack, in which the malware was used, was conducted in several stages and targeted the naval forces of Italy and their contractors.

The attacker installed a dropper written in Delphi that uploaded the second-stage payload and executed it. Then HTTPS POST requests were used to send system information collected from the victim's machine using the command line. After this, the upnphost.exe is launched, which is probably the final payload. At the same time, another sample of sdbn.dll was discovered, which communicates with marina-info.net C&C via HTTPS. According to some researchers, this .dll file is a new version of the X-Agent backdoor; however, analysis by Z-Lab CSE Cybsec specialists neither confirmed nor denied this assumption.

The APT28 group (Fancy Bears, Sofacy Pawn Storm, Sednit, and Strontium) was first discovered in 2004. It is known for attacks in the political, informational and military spheres.

APT Title	Regions Attacked	Operation Start
PowerPool	Russia, Ukraine, Poland, Germany, UK, USA, India, Philippines, Chile	May 2018

A recently discovered group, PowerPool, started to use the 0-day vulnerability CVE-2018-8440 in their malicious campaign. The vulnerability affects Microsoft Windows from 7 to 10, namely the interface of Advanced Local Procedure Call (ALPC) in Windows Task Scheduler. It provides Local Privilege Escalation that allows the attacker to elevate privileges to SYSTEM.

Initially, the vulnerability was discovered by a cybersecurity expert, who posted it on Twitter. Hackers took source code from the Proof-of-Concept exploit in the GitHub repository (the link was in a tweet) and partially modified it. Two days later, the exploit was used in a campaign against Russia, Ukraine, Poland, Germany, the UK, the USA, India, the Philippines, and Chile.

It was found that the main vector for the initial compromise was a spam message with the attached malicious software for the first stage. Due to the small number of goals, the experts concluded that the hackers carefully selected target emails and their main purpose is espionage.

APT Title	Regions Attacked	Operation Start
Sapphire Mushroom (APT-C-12, BlueMushroom)	China	March 2011

In July 2018, 360 Threat Intelligence Center published a study on an espionage campaign called Operation NuclearCrisis. It was targeted at research institutions, government agencies, and the defense agencies, mostly in China. It was noted that the attacks were conducted by a previously unknown cybercriminal group called Sapphire Mushroom, which has been in operation since 2011.

The main infection vector is sending spearfishing messages with a malicious attachment. We can distinguish several types of mailouts, which are classified by the attached file.

Initially, the attackers used a WinRAR archive that contained the SCR files disguised as Word documents. Experts discovered a file that was disguised as the address book file, and to better mask the bait the attacker used RLO. RLO is a Unicode Controller, which is used to display text for the Middle East (right to left). The attacker hides

the real extension of the file, inserting the RLO control character into the file name, which forces the charaters to be displayed right to left.

Then, the hackers sent out phishing messages that would trick users into opening the attached LNK PowerShell script that loaded sensitive information and user files, and installed a malicious backdoor for further access to and control over the victim's computer. The methodology of the attack actually uses a fairly new approach to the use of LNK files: the use of Amazon AWS S3 and cloud infrastructure protocols to exfiltrate confidential user information.

In the latest attacks, it was noted that Sapphire Mushroom started to use a Digital Ocean cloud service as a C&C but they also used a SinaAppEngine (SAE) cloud service to create C&C management infrastructure.

APT Title	Regions Attacked	Operation Start
A deliberate attack on participants of International Military-Technical Forum Army 2018	Russia	August 2018

In August 2018, FortiGuard Labs experts discovered a malicious PPSX file exploiting CVE-2017-0199, which was designed for English-speaking users. The file name was Exhibition and upon further examination it was discovered that it targeted the annual International Military-Technical Forum Army 2018, which is held in Russia. The event is one of the largest exhibitions of military weapons and machinery.

It was discovered that the file was formed on the eve of the forum, which is held from August 21 to 26.

After exploitation, the hackers uploaded BISKVIT malware on a victim's computer. The Trojan has a modular structure and is written in C# programming language. There is no overall picture of malware functionality, as the components are only downloaded and uploaded on the fly. Proven features of this Trojan:

- Downloading files and components
- Implicit execution of downloaded and local files
- Downloading dynamic configuration files
- Self-updating
- Removal

The malware appears as the legitimate file Synaptics Pointing Device Driver.

APT Title	Regions Attacked	Operation Start
Sidewinder (T-APT-04)	Pakistan	May 2018

In May 2018, the Sidewinder cyber-crime group was discovered. The APT group is assumed to be located in India, and the earliest attack dates back to 2012. The main activity is cyber espionage against military targets from South Asian countries, such as Pakistan.

The criminals used a decoy document in which they exploited the CVE-2017-11882 vulnerability. The vulnerability affects Microsoft Equation formula editor (a specialized program for creating and editing mathematical formulas, EQNEDT32.EXE) and allows malicious code to be run without user interaction. After exploiting the vulnerability, the Powershell payload was deployed, which then launched the RAT.

APT Title	Regions Attacked	Operation Start
TEMP.Periscope (Leviathan)	USA, Europe, Hong Kong, Cambodia	April 2017

FireEye specialists discovered Chinese hackers' activity from the TEMP.Periscope group targeted against Cambodia's policy, including attempts to compromise Cambodian government structures that are involved in election monitoring, as well as against opposition figures. This campaign was conducted on the eve of the July 29, 2018 general elections in the country.

TEMP.Periscope sent spear phishing emails with malicious software AIRBREAK. AIRBREAK is a JavaScript-based backdoor also known as Orz, which extracts commands from hidden lines on compromised web pages and profiles in legitimate services controlled by criminals.

In addition to the previously known AIRBREAK, the hackers expanded their arsenal with new families of Trojans DADBOD and EVILTECH. DADBOD is a tool used to steal users' cookies. EVILTECH is a JavaScript sample that executes a simple RAT with support for uploading, downloading, and launching arbitrary JavaScript.

During the infection process, EVILTECH is launched on the system, which then causes redirection and, possibly, loading of additional malware or connecting to another system controlled by the criminal.

APT Title	Regions Attacked	Operation Start
OilRig (APT34, Helix Kitten)	Middle East	May 2018

The Iranian APT group OilRig is continuing its attacks on government institutions and organizations in the Middle East. Researchers report three targeted phishing e-mails which were sent on behalf of one of the government agencies whose account is likely to have been hacked. In two cases, the letters were sent to the addresses of a Middle East technology company and contained an executable file that establishes the QUADAGENT backdoor. The malicious program secretly created a task in the autorun list, after which it tried to contact the command server via HTTPS, HTTP or DNS tunneling.

The third wave of letters was focused on a government agency and contained a PE file created using the .NET framework. When launched, the malware displayed a fake error message to distract the victim's vigilance. The script continued operating in the background and also downloaded QUADAGENT to the device.

In an attempt to avoid detection and employing anti-analysis tactics, the OilRig group used an open source tool called Invoke-Obfuscation to confuse the code used for QUADAGENT. Invoke-Obfuscation is freely available through the Github repository and allows the user to change the visual representation of the PowerShell script by simply choosing the right obfuscation method.

In August 2018, OilRig returned to the previously used BONDUPDATER backdoor. The BONDUPDATER Trojan contains basic backdoor functions that allow hackers to upload and download files and execute commands. BONDUPDATER, like other OilRig tools, uses DNS tunneling to communicate with the C&C. The specialists observed several attacks on Middle Eastern governments using the updated version of BONDUPDATER malware, which now includes the ability to use TXT records in its DNS tunneling protocol to connect to the C&C.

OilRig (APT34) is a cyber-crime group that has been in operation since the end of 2015 and, presumably, is located in Iran, and has connections with the Iranian government. Most commonly, it attacks organizations and commercial institutions of the Middle East, as well as countries in which there is interest for Iran. The main objective of the group is espionage. The group uses various malware and tools. In the most recent incidents, the following Trojans were noticed: POWRUNNER backdoor and POWBAT malware exploit-pack.

APT Title	Regions Attacked	Operation Start
Gaza Cybergang (Molerats)	Palestine	March 2018

In July 2018, Check Point Threat Intelligence Team researchers published information on the criminals of Gaza Cybergang who had resumed attacks on companies in the Middle East, in particular against the Palestinian authorities.

The attack started with phishing emails sent to targets by email. The letter contained a self-extracting archive with two files: a Word document and a malicious executable file. The Word document serves as bait and is supposedly written on behalf of the Palestinian political and national steering committee (Palestinian Political and National Guidance Commission). The document distracts the victim while the malware installs itself in the background.

The malware has several modules that do the following:

- Take a screenshot of the infected machine and send it to the C&C server.
- Send a list of .doc .odt .xls, .ppt, .pdf and other documents.
- Gather information about the system.
- Reboot the system.
- Self-destruct an executable file.

As soon as the hackers find the required information, the second phase of the attack begins, in which the victim's computer downloads additional modules and/or other malware.

Gaza Cybergang (Molerats) has been active since 2012, and is mainly focused on government institutions in MENA. Cybercriminals use phishing emails, counterfeit websites, social engineering techniques, and various RATs. The main objective of the group is to gather intelligence.

APT Title	Regions Attacked	Operation Start
WindShift	Middle East	2017

WindShift group managed to conduct cyber espionage activities undetected for several years. Their victims were employees of government agencies and critical infrastructure companies in Middle Eastern countries.

Preparation for the attack began long before the attack itself. The attackers created fake social media accounts (Linkedin, Facebook, Twitter, Instagram, Google Plus), and then sent friend requests to their future victims. The attacker communicated with the victims via private messages and lured useful information such as phone numbers, email, etc from them.

The attackers followed the victims through innocent messages for 6 months to a year. They identified their interests, location, computer used, frequency of clicks, etc. Then the attackers used the obtained data to create special content, and then began the attack.

In particular, the hackers sent victims a phishing email with a link to a website they control, where a drive by attack on an Apple Mac uploaded WindTale and WindTape malware.

WindTale.A is a signed backdoor that steals .txt, .pdf, .doc .docx, .ppt, .pptx .db., .rtf, .xls, and .xlsx files. It was first used in January 2017. WindTale.B appeared in January 2018 and is a rewritten version of WindTale.A. In addition to data theft, the malware also uploads WindTape malware to the victim's computer. The main function of the WindTape Trojan is to make screenshots and send them to the attackers.

APT Title	Regions Attacked	Operation Start
Gorgon Group	Spain, UK, USA, Russia	February 2018

Since February 2018, experts have been monitoring the campaign by members of the Pakistani group, Gorgon Group, targeted at governmental organizations in the UK, Spain, Russia, and the United States.

The group was discovered because they used a popular service to shorten the URL. Researchers from Palo Alto Networks Unit 42 were able to obtain data on the number of clicks on the links and other information associated with the Gorgon Group.

Criminals send their victims phishing e-mails regarding issues of terrorism as well as military and political problems in Pakistan and neighboring countries. The emails contain a Word document with an exploit for the CVE-2017-0199 vulnerability. When the victim opens the document, the computer loads a script into Visual Basic with PowerShell commands. Then the attacker can execute commands and upload malicious software to the compromised system.

In the case of the Gorgon Group, the victims got one of the three malware families for data theft and espionage: NanoCoreRAT, QuasarRAT, or NJRAT.

APT Title	Regions Attacked	Operation Start
Turla (Snake, Uruburos, Venomous Bear, KRYPTON)	Europe	2016

In the summer of 2018, malicious activity of Turla group using Turla Outlook Backdoor was discovered. The malware used PDF attachments as a channel for communication with a C&C server. The attachments were transmitted via Microsoft Outlook or The Bat! in older versions of the backdoor.

Hackers used the backdoor to steal confidential data of European state institutions.

Commands were sent in an email with a specially crafted PDF attachment. The backdoor restores the container from PDF documents. A container is a BLOB object of a special format that contains encrypted commands for execution by backdoor. Commands are contained in the last part of the container structure. They are encrypted with MISTY1 and compressed using bzip2.

Files requested by the backdoor command are also exfiltrated in a specially created PDF document attached to the emails. This method provides a high level of stealth.

The backdoor generates reports at regular intervals and sends them to the operators. The report contains unique identifiers, including MAC address, a complete log file, and the command execution results, if any. It then encrypts the data using MISTY1 and creates a valid PDF file with encrypted data. Before the encrypted BLOB, there is a 1x1 .jpeg white image, which is hard-coded in the malware. This method allows a valid PDF to be created that, when opened, only shows one blank page. After that, the backdoor attaches the PDF and sends the email to the attacker. The report is sent through callback functions in the Outbox. This means that the email will be sent alongside legitimate messages to avoid detection.

Turla (Snake, Uroburos, Venomous Bear, KRYPTON) is a Russian criminal cyber group. It is believed that the group has been in operation since 2007. The main purpose of the Turla attacks is to steal data from governmental, diplomatic, military, educational, research and pharmaceutical organizations.

APT name	Regions attacked	Operation start
APT10 (Menupass)	Japan	July 2018

In July 2018, security experts detected what appears to be APT10 (Menupass) activity targeting the Japanese media sector. APT10 is a Chinese cyber espionage group that has been tracked since 2009.

In this campaign, the group sent spear phishing emails containing malicious documents that led to the installation of a new version of the UPPERCUT backdoor. The attack starts with Microsoft Word documents containing a malicious VBA macro being attached to spear phishing emails. Although the contents of the malicious documents are unreadable, the Japanese titles are related to maritime, diplomatic, and North Korean issues.

The latest version of UPPERCUT has a number of improvements in sending and receiving an HTTP response and the hashing algorithm. The most significant change is in the way the backdoor initializes the Blowfish encryption key, which makes it harder for analysts to detect and decrypt the backdoor's network communications.

APT Title	Regions Attacked	Operation Start
APT-C-35 (Donot)	Kashmir, Pakistan, India	July 2017

Thanks to the popularization of smartphones and mobile networks around the world, an increasing number of hacker organizations are targeting mobile phones, even in combination with a PC. The last attack of cybercriminals from APT-C-35 revealed a new RAT, which was designed for mobile devices. The Trojan was disguised as KNS Lite (Kashmir news agency).

Experts claim that other masking RATs were discovered, which allowed them to trace the initial activity of the Trojan in July 2017. Experts suggest that attackers used a spear phishing newsletter via email or text. Phishing websites were discovered as well.

The Trojan is a RAT, which contains the standard action for this type of malware: recording and uploading contacts/call logs/messages.

APT-C-35, also known as Donot, is focused on cyber espionage in governmental and other institutions in the Kashmir region and steals confidential information.

APT Title	Regions Attacked	Operation Start
DarkHotel (APT-C-06, Tapaoux, Pionee)	Italy	July 2018

A year later after the last attack, DarkHotel resurfaced, adding 0-day vulnerability CVE-2018-8174, which was called a Double Kill, to its arsenal. CVE-2018-8174 is a use-after-free (UAF) vulnerability that affects the implementation of VBScript in Internet Explorer and Microsoft Office. It uses a technique which consists of “damaging” two memory objects and changing the type of one object to Array to make reading and writing address space possible. Another object’s type is changed to Integer to get the address of the arbitrary object.

In addition, they were later spotted using another 0-day vulnerability, CVE-2018-8373, which also affects the VBScript engine in recent versions of Windows. Attackers exploited a UAF-type vulnerability located in the vbscript.dll library that was left unpatched in the last VBScript engine. This issue allows an attacker to execute code with the privileges of the current user.

During the attack, an image with hidden data (steganography) is extracted at a specific address. After the decryption, an image forms a payload, used for remote control and providing the ability to download additional plugins for: collecting system information via the command line; collecting passwords from the browser and storing them in encrypted form using the AES encryption algorithm; creating screenshots, keylogger.

DarkHotel (APT-C-06, Tapaoux, Pioneer, Luder, Karba, Nemim, SIG25, Dubnium, Fallout Team) is a criminal cybergroup that has been in operation since 2007. The main targets of the attacks are guests of expensive hotels, people in high-level positions, and political organizations, mainly in Northeast Asia.

APT Title	Regions Attacked	Operation Start
Red Signature targeted attack	South Korea	July 2018

Security experts have discovered a targeted campaign that was called Red Signature. It lasted for 2 weeks from July 17 to 31. The cybercriminals used the compromised support server of a South Korean software vendor to send out a malware kit disguised as updates.

This spring, hackers stole the security certificate to confirm the validity of their files. Then, the scammers created a ZIP archive with a 9002 RAT Trojan and placed it on a specially deployed host. The file was signed with a stolen certificate, and was perceived as a normal update. Hackers broke into the server of the software vendor and made changes to the algorithms of its operation to deliver malicious updates.

The targeted nature of the attack is confirmed by the fact that the scheme of infection only started when certain IP addresses sent requests. After unpacking, 9002 RAT uploaded a set of malware to the compromised device. The payload included applications for stealing system data, personal information, and passwords stored in the browser or SQL database.

In addition, the computer was infected with malware that exploits the critical CVE-2017-7269 vulnerability in Internet Information Services v. 6. The vulnerability can be exploited using a specially configured request with the PROPFIND command. With its help, the attacker could cause a denial of service or execute arbitrary code.

APT name	Regions attacked	Operation start
Bahamut	India, Qatar	July 2018

Security experts at Cisco Talos reported on spyware campaigns using malicious MDM platforms. The identified platforms are used by criminals to download compromised versions of Telegram, WhatsApp and IMO messengers, as well as a fake Safari browser to the target devices.

The backdoor embedded in legitimate services allows threat actors to install five malicious applications on the victim's smartphone. The first two evaluated the characteristics of the phone, one application was aimed at stealing SMS messages, and the rest determined the location and collected other data, such as images. All stolen information was transferred to the C&C server.

Through analysis of the source code of the MDM platform and malware, security specialists managed to link the malicious activity to the Bahamut group that had previously infected phones in India. Experts believe that criminals have been conducting targeted attacks to spy on certain people for political or economic reasons since 2015. Specialists discovered that iPhones from India and Qatar were registered on the platform.

APT Title	Regions Attacked	Operation Start
LuckyMouse	Central Asia	March 2018

Experts discovered a new malicious campaign of Chinese LuckyMouse group targeted at government agencies in the Middle East. Researchers believe that the attack was targeted and associated with a high-level meeting.

Apparently, the campaign demonstrates the interest of LuckyMouse in Central Asia and the political agenda around SCO.

As experts point out, the threat consists of three models:

- An installer written in C++, which decrypts and records the driver file in the appropriate system directory. The installer adds a driver to the Windows startup and the encrypted body of the Trojan goes to the system registry.
- A driver (NDISProxy), which, apart from filtering network traffic on 3389 port (Remote Desktop Protocol, RDP), is responsible for the Trojan decryption and its implementation into the memory.
- A RAT Trojan written in C++. Launches an HTTP server and works together with the driver. It passively waits for messages from the control server in two possible communication channels: 3389 port (RDP) and 443 port (HTTPS).

No directed phishing or watering-hole activity was discovered. We can conclude that this time the campaign operators went without social engineering and likely used a vulnerability discovered in the network infrastructure of the victims.

The Chinese hacker group LuckyMouse (Iron Tiger Threat Group-3390, EmissaryPanda, APT27) has been active since at least 2010.

APT Title	Regions Attacked	Operation Start
OceanLotus (APT32, APT-C-00)	East Asia	Summer 2018

In the summer of 2018, ESET experts discovered a new backdoor in the arsenal of the OceanLotus cybercriminal group. To convince the victim to run a malicious dropper, the attackers use different methods:

- Double extensions and fake application icons (Word, PDF, etc.)
- Fake installers

The OceanLotus group uses an old and widely known technique in one of the executable files of Symantec and McAfee. The point is to use the process of loading libraries of a legitimate and signed .exe file by writing a malicious library in the same folder. This will cause malicious behavior to look legitimate, as these actions are performed in a trusted executable process.

At first, the malware attempts to load its resources and decrypt them with the RC4 algorithm. These resources contain data used for configuring the backdoor.

This is a full backdoor, which provides its operators with a number of possibilities: manipulation with the file, registry, and processes; downloading additional components; obtaining a system fingerprint.

OceanLotus (aka APT32, APT-C-00, SeaLotus, Cobalt Kitty) is believed to be a Vietnam-based APT group that has been around since late 2009. The group typically targets companies, individuals and government networks of interest to the Vietnamese government in East Asian countries, particularly Vietnam, the Philippines, Laos and Cambodia, as well as Germany and the United States. The list of targeted entities includes government agencies, human rights organizations, oil exploitation entities, and banks.

Threats to blockchain projects and cryptocurrencies

GROUP-IB

GLOBAL CYBER SECURITY COMPANY

APT Title	Regions Attacked	Related Notifications	Operation Start
Lazarus	Global	CP-1729	July 2018

In August 2018, cybercriminals from the Lazarus group became active again in stealing cryptocurrency. This time they engaged in malware distribution using corporate addresses of cryptocurrency exchanges. They offered to install an app for trading called Trade Pro Celas by Celas Limited. The link from the letter led to the official website of the developer, who had a valid SSL certificate issued by Comodo CA.

It was found that Celas Trade Pro is based on the open source code of Qt Bitcoin Trader. Open source Qt Bitcoin Trader only includes the main program, while the modified application includes a backdoor module called Updater. Firstly, the backdoor collects local information, including a list of processes, computer name and system information. Then it encrypts the collected information and sends it to the command server. It then downloads malicious code from the cloud for execution.

The software has versions for Windows and Mac so it also supports cross-platform attacks.

Lazarus (other names: Dark Seoul Gang, HIDDEN COBRA, Guardians of Peace) is a cybercrime group that has been in operation since 2007. As experts found out, the members of the hacker group are from North Korea.

APT Title	Regions Attacked	Operation Start
The attack on the Tech Bureau Corp cryptocurrency exchange	Japan	September 2018

The cyber criminals hacked the Japanese cryptocurrency exchange Bureau Tech Corp, where hackers managed to steal $60 million (6.7 billion Japanese yen) in the form of different types of digital currencies. The attackers gained access to the Bureau network Tech Corp, located in Osaka, and for two hours enjoyed this access to withdraw funds. As stated by a representative of the Financial Services Agency, the attackers compromised the computer of a Tech Bureau Corp employee.

The incident occurred on September 14, 2018, and it is reported that it was only September 17 that representatives of the Japanese stock exchange discovered the fact of intrusion of unknown persons in the exchange network. To eliminate the effects of an attack, Tech Bureau Corp froze all transactions on the exchange.

APT Title	Regions Attacked	Operation Start
The attack on the KICKICO blockchain platform	Global	July 2018

On July 26, 2018, unknown individuals stole more than 70 million KICK tokens (KickCoin), which was the equivalent of 7.7 million dollars from the blockchain crowdfunding platform KICKICO.

It was established that the unknown third party was able to access the private key, which the developers used to control the KickCoin smart contract. The criminals used a key to destroy the tokens of about 40 addresses, and then created a new wallets that they were able to control and that contained the same amount. In the end, the total number of tokens remained unchanged, which helped the criminals to avoid the attention of automated security mechanisms.

APT Title	Regions Attacked	Operation Start
Attack on Bancor cryptocurrency exchanger	Global	July 2018

On July 9, 2018, the decentralized cryptocurrency platform Bancor was forced to suspend work and reported that an unknown individual had compromised the wallet used to update the smart contracts.

It is reported that the unknown attackers managed to steal more than $ 12 million in ETH equivalent (24,984 ETH). 229,356,645 NPXS (approximately $1 million) and 3,200,000 BNT ($10 million) were also stolen. After the theft of cryptocurrency, the attackers used the service to instantly convert cryptocurrency Changelly, attempting to exchange a portion of the stolen funds.

Unfortunately, there is no more detailed information about the technical side of attacks.

Bancor is a protocol to create a smart token that offers a new standard of automatic exchange cryptocurrencies directly through their smart contracts, bypassing stock exchanges and other intermediaries. During the ICO in 2017, the project attracted more than 140 million dollars in just a few hours.

APT Title	Regions Attacked	Operation Start
Attack on the Newdex cryptocurrency exchange	Global	September 2018

Hackers used a vulnerability in the security system of the platform EOS and stole cryptocurrency equivalent to 58,000 dollars.

The vulnerability of the platform is that it allows any user to create their own token, and come up with the name that may even be the same as the original, as happened in this case. In addition, the decentralized cryptocurrency exchange Newdex does not use smart contracts. This means that it does not have the opportunity to verify the individuals entering the token platform.

In the published report of the exchange, it is stated that EOS account number oo1122334455 released 1 billion fake tokens called EOS. After a short test, the owner of the account began to place large orders for the purchase of real coins. The exchange processed 11,800 similar orders. After that, the hackers managed to exchange the fake EOS tokens for real BLACK, IQ and ADD tokens.

Data leakage

GROUP IB

GLOBAL CYBER SECURITY COMPANY

- Veeam is a Swiss company specializing in the development of software for virtualization, subjected to a large dataset of potential danger, as they were stored on publicly accessible services. The dataset consisted of 445 million records and had a size of over 200 GB. Subsequently, this problem was eliminated.
- In February, the network obtained a large amount of personal data of the voters in Texas. The leaked records contained personal information about millions of Texan residents. All of this was stored on an unsecured server that did not even have a password. The personal information was contained in a single file and consisted of about 14.8 million records. In Texas alone, there were 19.3 million voters. Data found specializing in leaks, a researcher from New Zealand known under the name Flash Gordon.
- The company Fiserv, the largest provider of services to financial companies, recorded in its web platform for banks a dangerous vulnerability that allows to access personal data and financial information of customers of hundreds of banks. The problem was discovered by security researcher Kristian Hermansen. The expert noticed that in sent using Fiserv reports of operations, there is a special room for the event. Using a simple method of brute force, an attacker could access the data of other clients. Thus, it could potentially leak data.
- At the end of August to the us servers a large Telecom operator T-Mobile was carried out unauthorised access. In the hands of the unknown attackers got the usernames, email addresses, phone numbers, zip codes, billing addresses, and encrypted passwords, as well as information about the types of accounts (prepaid or postpaid), the leak affected 2 million users.
- In mid-August, it was reported that law enforcement authorities of Australia charged a 16-year-old (name not disclosed), who repeatedly entered the network of Apple last year. Currently, it is unknown which part of the infrastructure the accused penetrated, it is reported that he stole about 90 GB of private data. During a search of the teenager’s home seized two laptop, smartphone and hard disk, which helped to associate it with penetration into Apple's network. On one of the laptops was a folder called "Hacky Hack" that contains stolen from Apple files.
- In late August, Chinese media reported that Chinese-language underground online on sale a database containing information on 130 million visitors in Chinese hotels. The cost base is estimated at 8 bitcoin (about $56,000). According to the seller, this data refers to Huazhu Hotels Group Ltd, one of China's largest hotel chains. The database contains the following information: the official registration data from the site (number ID, mobile number, email, login and password), registration data of the hotel (name, ID number, home address, date of birth), booking details (name, card number, mobile telephone number, date of arrival, date of departure, the internal ID of the hotel room number). According to preliminary data from the Chinese security company Zibao, the leak was the fault of the employees who by mistake downloaded database copies on GitHub that were not meant for open publication.